

Auditoria Forense e Plano de Resgate Técnico

Ecossistema Vanna AI

Bruno Henrique Carneiro da Silva Diego Carvalho Cavalcante
Fábio Henrique Lisboa de Souza Flávio Henrique de Jesus Cruz
Guilherme Sollano Andrade dos Santos José Weverton de Oliveira Vilar
Leonardo Caricchio do Nascimento Matheus Henrique Silva de Melo

Engenharia de Software (COMP0503)

02 de Junho de 2026

- **Risco: Lacuna na Engenharia de Requisitos (Mudança de Escopo oculta)**
 - **Evidência:** Issue #659 e PR #660. Uma discussão iniciada como correção de erro (*documentation_collection*) escalou para refatoração de *embeddings* sem nenhum RFC ou documento de arquitetura formalizando a alteração.
- **Risco: Vulnerabilidade de Manutenção ("Herói Único")**
 - **Evidência:** Gráfico de contribuições do repositório revela picos severos de *crunch time* e um mantenedor central responsável por 399 *commits*, contra apenas 60 do segundo contribuidor mais ativo.

- **Risco: Violação Crítica do Princípio da Responsabilidade Única (SRP)**

- **Evidência:** Arquivo `src/vanna/legacy/base/base.py`. Trata-se de uma *God Class* confirmada com exatas 2.125 linhas e 65 métodos, aglutinando geração de SQL, manipulação de banco de dados e execução de IA no mesmo escopo.

- **Risco: Retrabalho e Quebra Parcial do DRY**

- **Evidência:** O método `_extract_tool_calls_from_message` possui a mesma lógica de tratamento de JSON repetida em diferentes implementações de `LlmService` (OpenAI, Anthropic), em vez de estar isolada em uma classe utilitária.

- **Risco: Falha de Gerenciamento Criacional (Conexões Redundantes)**

- **Evidência:** O arquivo `chromadb/agent_memory.py` invoca `chromadb.PersistentClient()` a cada nova instância, sem a proteção de um padrão *Singleton* para reaproveitar a conexão vetorial.

- **Risco: Delegação Insegura de Execução (Ausência de Padrão Comportamental)**

- **Evidência:** O *Agentic Loop* (`core/agent/agent.py`) confia cegamente no modelo. Ao identificar o comando, executa `await self.tool_registry.execute(tool_call, context)` sem nenhuma corrente de validação prévia.

Diagnóstico da Vulnerabilidade no Vanna 2.0

- **Assimetria de Design:** O projeto utiliza de forma inteligente a abstração de *Middlewares* para a comunicação externa com as APIs de LLM, mas ignora completamente este padrão na sua camada mais sensível: a execução de ferramentas.
- **Execução Direta:** O método `await self.tool_registry.execute()` roda a ação baseada unicamente na saída textual gerada pela Inteligência Artificial.
- **Risco Crítico:** Uma eventual alucinação do modelo contendo instruções destrutivas (ex: DROP ou DELETE) atinge o banco de dados de produção instantaneamente, sem nenhum mecanismo de contenção.

Proposta: Escudo de *Middlewares* de Execução

- **Isolamento de Responsabilidades (SRP):** Criação da entidade `ToolExecutionRequest` para circular por uma corrente de interceptadores independentes.
- **Elo 1 - `RateLimitMiddleware`:** Validação das cotas de uso do usuário, prevenindo gargalos operacionais ou custos excessivos de API.
- **Elo 2 - `SQLSanitizationMiddleware`:** Inspeção rigorosa dos argumentos da chamada (ex: `args.sql`) para barrar operações DDL/DML não autorizadas.
- **Elo 3 - `FinalExecutionMiddleware`:** Camada de execução física (`sql_runner`), atingida exclusivamente se a requisição sobreviver intacta a todos os elos anteriores.

Roadmap de Maturidade: Rumo ao Nível G (MPS.BR)

Objetivo: Institucionalizar processos em 90 dias para superar o atual estágio informal (Pré-Nível G).

Ação 1: Institucionalizar a Gerência de Projetos (GPR)

- **Foco:** Dissolver o anti-padrão de "Herói Único" e garantir cadência previsível.
- **Implementação Tática:**
 - Implantação de *GitHub Projects* (*Backlog, In Progress, Review, Done*).
 - Política de rodízio: designar pelo menos dois *co-maintainers* com permissões de *merge*.
 - Criação de um **Registro de Riscos** formal no *wiki* (mapeando instabilidade de APIs e *vendor lock-in*).
- **Prazo:** Semanas 1 a 3 (**Prioridade Crítica**).

Ação 2: Formalizar a Gerência de Requisitos (GRE)

- **Foco:** Erradicar mudanças de escopo ocultas e garantir rastreabilidade bidirecional.
- **Implementação Tática:** *Issue Templates* obrigatórios (com Critérios de Aceitação) e uso de *ADRs* (*Architecture Decision Records*) para documentar alterações estruturais.
- **Prazo:** Semanas 2 a 5 (**Prioridade Alta**).

Ação 3: Elevar a Qualidade do Produto (QPR)

- **Foco:** Proteger a base de código contra regressões e vulnerabilidades de IA.
- **Implementação Tática:** Estabelecer *Definition of Done* (DoD) inflexível. *Pull Requests* bloqueados nativamente até aprovação em CI/CD (cobertura *pytest* $\geq 70\%$) e varredura SAST (Bandit) contra injeções SQL.
- **Prazo:** Semanas 3 a 8 (**Prioridade Alta**).